BÁO CÁO BÀI TẬP CÁ NHÂN 3

Production Readiness Lab — Xóa mềm và khôi phục tài khoản

Sinh viên / mã	Biến thể / nhóm	Repo / baseline
Phạm Duy Hải · 23001871	APP-03 · VT-068 · SE2026-T18	4PMs-3Workers/Production-Readiness-Lab
Vai trò: Nhóm trưởng	Nhánh: feature/soft-delete-account-restore	12a74f7308550ccc294a783edde79db267a526d1

PR #67 — Draft, chưa merge. Cam kết: “Tôi chịu trách nhiệm về toàn bộ code, test và nội dung bài làm; tôi đã khai báo việc sử dụng AI.”

1. Đặc tả và tiêu chí chấp nhận

Problem statement. Quản trị viên cần xóa mềm và khôi phục tài khoản để ngừng quyền sử dụng mà không làm mất lịch sử liên kết. Khôi phục phải đưa tài khoản về đúng trạng thái active trước khi xóa; API phải ngăn người dùng thường nhìn hoặc sửa tài khoản của người khác.

Acceptance criteria. AC1: DELETE của ADMIN giữ nguyên user row, đặt deleted_at, lưu trạng thái active cũ, chuyển inactive, thu hồi session và ghi audit trong cùng transaction. AC2: tài khoản đã xóa bị ẩn khỏi danh sách mặc định; ADMIN chỉ xem khi đặt include_deleted=true, STUDENT/STAFF không đọc hoặc ghi API quản trị. AC3: chỉ tài khoản đã xóa mới restore được; trạng thái active cũ được phục hồi, marker được xóa, session cũ không được hồi sinh. AC4: appointment, notification và FK history được giữ; không xóa ADMIN/STAFF cuối cùng hoặc STAFF đang có lịch chiếm chỗ. AC5: thao tác cần expected_updated_at hiện tại, Origin hợp lệ và CSRF; version cũ trả 409 và không tạo side effect.

Ràng buộc phi chức năng. NFC1: kiểm chứng 120 tác vụ đồng thời, p95 riêng cho delete/restore ≤3.5 giây. NFC2: phân quyền phía server; thay đổi account, session và audit nguyên tử. NFC3: không trả hoặc ghi password, hash, token, hay nội dung tư vấn vào response/audit.

> Invariant quan trọng nhất: xóa mềm không xóa account hoặc dữ liệu FK; deleted_at và is_active_before_delete hoặc cùng rỗng hoặc cùng được đặt; account bị xóa luôn inactive. Restore phục hồi cờ đã lưu, nhưng không làm session revoked hợp lệ trở lại.

2. Kế hoạch AI và review theo repository

Prompt chính (tóm lược): đọc đặc tả VT-068 và branch PR; trước khi chỉnh sửa, đề xuất plan, assumptions, invariant, file liên quan và evidence cần kiểm tra; chú ý quyền truy cập, test theo state transition và cách đánh giá 120 tác vụ/p95.

Plan: giữ user row, thêm cột lifecycle cùng check/index và migration; triển khai ADMIN-only DELETE/restore trong transaction có version precondition, audit và session revocation; ẩn deleted account khỏi query mặc định; viết unit transition tests, MySQL API tests và load harness; kiểm tra schema/OpenAPI, worker/release compatibility và query plan.

Review assumptions: tôi không chọn cascade-delete vì model và integration tests cho thấy appointment/notification phải còn lại. Tôi cũng bác bỏ việc restore luôn active=true hoặc tái dùng session: unit test có trường hợp account trước đó inactive, integration test giữ session ở trạng thái revoked. Cuối cùng, 120 tác vụ không thể dùng chung actor session; harness bắt buộc 120 account ID và cookie riêng. Các kết luận này được đối chiếu với code/test thật, không dựa vào câu trả lời của AI.

Một điểm cần chỉnh trong kế hoạch là không thể coi thao tác xóa và thu hồi phiên là hai bước độc lập. Nếu xóa commit nhưng revoke lỗi, tài khoản không hoạt động trong khi session cũ còn dùng được. Vì vậy contract yêu cầu chúng cùng transaction; test failure path phải kiểm tra cả account, session và audit sau rollback, không chỉ status code.

Khi đối chiếu repo, tôi cũng kiểm tra các cập nhật cần thiết quanh lifecycle: migration được nhận diện bởi worker và release manifest, OpenAPI có restore route, còn gateway có route map riêng được sinh từ danh sách endpoint. Đây là lý do plan không dừng ở service và router: một schema mới có thể làm worker từ chối chạy nếu allowlist revision bị thiếu, dù unit test service vẫn xanh.

Các vùng file trong PR: models/user.py, repositories/users.py, services/admin_accounts.py, api/admin_accounts.py, schemas và migration; unit/API tests, OpenAPI/docs và tools/load/account_lifecycle.py. Implementation đã có trên nhánh trước lượt hoàn thiện báo cáo này; tôi review diff và evidence, không nhận là AI vừa sinh toàn bộ patch.

3. Chiến lược test và state transition

Mô hình chính: Active(true/false) —delete có quyền/version đúng→ Deleted(inactive, lưu prior active) —restore có quyền/version đúng→ Active(prior active). Delete lần hai, restore account live, sai role/CSRF, stale version, xóa role cuối hoặc STAFF còn lịch là transition bị từ chối. Dữ liệu chọn gồm cả prior active=true/false, ba role, session tồn tại, appointment/notification liên kết, actor trái quyền và version hiện tại/cũ.

Unit kiểm tra chuyển trạng thái, schema version, query filter và kiểm tra input harness. Integration/API với MySQL 8.4 kiểm tra quyền, transaction, audit/session/FK, constraint và cạnh tranh. E2E phù hợp cho luồng admin trên desktop/mobile khi API E2E chạy. Không cần mở rộng sang email/password recovery hay UI toàn ứng dụng; mock/SQLite không đủ chứng minh khóa và constraint InnoDB.

Tôi phân tầng vì mỗi lớp trả lời một câu hỏi khác nhau: unit tests nhanh xác nhận business rule và cả nhánh prior-active; integration tests mới xác nhận MySQL thực thi constraint, lock và rollback như dự kiến; E2E chỉ nên bao phủ hành trình admin quan trọng và trạng thái thông báo trên giao diện. Test không lặp lại cùng assertion ở mọi tầng nếu không thêm bằng chứng mới. Negative cases ưu tiên authorization, stale version và transition không hợp lệ; failure path cố tình làm commit thất bại để phát hiện dữ liệu nửa chừng.

Risk được xếp cao nhất cho việc xem hoặc sửa nhầm dữ liệu người khác, vì hậu quả là lộ dữ liệu; kế tiếp là mất lịch sử hoặc tạo trạng thái account/session không nhất quán. Các case stale version, role cuối và staff còn lịch bảo vệ những cạnh nghiệp vụ dễ bị bỏ qua. E2E không thay thế API authorization tests: UI có thể ẩn nút nhưng client vẫn gọi được endpoint trực tiếp.

ID / risk	Level · P	Dữ liệu / trạng thái	Kết quả mong đợi
T01 AC1	Unit · P1	Active=true; delete với version đúng	Deleted, inactive, prior=true
T02 AC3	Unit · P1	Deleted; prior=false; restore	Marker clear; vẫn inactive
T03 negative	Unit · P1	Delete lần hai	ACCOUNT_ALREADY_DELETED
T04 negative	Unit · P1	Restore account live	ACCOUNT_NOT_DELETED
T05 AC2	Unit/query · P1	Danh sách mặc định và include_deleted	Ẩn mặc định; ADMIN opt-in xem được
T06 privacy	API/MySQL · P0	STUDENT gọi delete/restore account khác	403; target/session/audit không đổi
T07 stale	API/MySQL · P1	ADMIN gửi expected_updated_at cũ	409; không mutate/audit
T08 failure	API/MySQL · P1	DB/commit lỗi giữa mutation	Rollback state/session/audit; 503
T09 consistency	API/MySQL · P0	Có session, appointment, notification; delete rồi restore	FK giữ; session revoked; audit đủ
T10 guard	API/MySQL · P1	STAFF đang có lịch hoặc role cuối	409; dữ liệu không đổi
T11 performance	Harness · P1	120 ID và 120 session riêng; delete + restore	P95 mỗi route; zero failure; ≤3500 ms
T12 input	Unit/harness · P1	ID/session trùng hoặc origin sai	Từ chối preflight, không gửi request

4. Test-first, implementation và bằng chứng

Baseline develop: 12a74f7308550ccc294a783edde79db267a526d1. Commit test-only đầu tiên 4d94be031603f4ba05d6d12fd1716014c3d6bb72 đặt contract test trước implementation; run #43578158304 fail đúng vì hàm mark_account_deleted chưa tồn tại. Run có thêm lỗi worker không liên quan, nên chỉ dùng làm RED evidence.

Patch PR được review qua diff: business guard, transaction, repository filter, route, migration constraints/index và tests; user row được giữ, audit và revoke nằm trong transaction, stale version bị chặn. Lần chạy local hiện tại: **.venv\Scripts\python.exe -m pytest tests/backend/unit/test_admin_account_lifecycle.py tests/load/test_account_lifecycle.py -q** → 12 passed in 1.38s. MySQL integration chưa chạy local vì chưa có database test riêng.

Trong lúc xử lý CI đỏ, acceptance workflow chỉ ra route-map sinh tự động chưa có đường dẫn DELETE/restore. Tôi chạy tools/infra/generate_gateway_routes.py rồi chạy lại --check; map hiện ghi nhận 42 business operations. Dependency audit cũng tìm thấy CVE-2026-126360 trên opentelemetry-api 1.45.1. Tôi nâng đồng bộ các package OpenTelemetry trong pyproject.toml và requirements.txt lên 1.45.2/0.66b2 theo

bản upstream có fix; sau đó cài lại editable package và chạy lại nhóm 12 test. Kết quả local pass, nhưng cần đợi CI mới xác nhận môi trường Linux và toàn bộ suite.

Phần CI đỏ ban đầu không cùng một nguyên nhân: route-map là artifact dự án có thể sửa ngay từ nguồn sinh, còn advisory chỉ ra dependency runtime cần được nâng ở cả khai báo trực tiếp lẫn file requirements. Tôi tránh sửa tay route-map vì lần sinh kế tiếp sẽ xóa mất thay đổi; với dependency, tôi nâng cả nhóm phiên bản liên quan để không trộn exporter/proto ở hai patch release.

5. Mutation, coverage và flaky risks

Mutation riêng ở branch feature/mutation-soft-delete-boolean, commit a7be787dde277c10870c056d8198ceda7340d47d: đảo guard boolean deleted-state. Run #43577431896 cho thấy test delete hợp lệ và delete lặp kill mutant; run có lỗi schema worker cũ khác nên không coi là suite pass. Mutation không nằm trong branch nộp.

Mutation này có ích vì guard là nơi ngăn xóa nhầm một account đã ở trạng thái deleted; đảo boolean làm đổi hành vi nghiệp vụ nhưng diff vẫn rất nhỏ, dễ lọt review mắt thường. Hai test khác nhau bắt được cả chiều cho phép xóa và chiều từ chối xóa lặp. Chúng không chứng minh mọi mutation đều bị phát hiện, nhưng cho một bằng chứng cụ thể suite có khả năng nhận diện lỗi đảo điều kiện được yêu cầu.

Không có pytest-cov trong môi trường nên không nêu line/branch percentage. Risk coverage: AC1 T01/T09; AC2 T05; AC3 T02/T04/T09; AC4 T09/T10; AC5 T07/T08/T12; risk quyền P0 T06/T09. Pass rate không tự chứng minh tính đầy đủ. Hai flaky risks chính: timestamp/precision có thể khác giữa Python và MySQL (nên kiểm tra microsecond round-trip, không sleep); fixture DB/shared schema có thể gây phụ thuộc thứ tự hoặc tranh chấp khi chạy song song (UUID riêng, teardown sạch). Concurrency phụ thuộc lịch scheduler và network latency; assertions cần dựa invariant, chưa có lần lặp đủ để kết luận flake rate.

6. Kiểm chứng tải và traceability

Runner tools/load/account_lifecycle.py dùng asyncio, pool tối đa 120, 120 target và 120 ADMIN cookie/CSRF phân biệt; mỗi target chạy delete rồi restore, ghi p95 tách theo route và failures. Có opt-in bắt buộc, remote chỉ HTTPS, fixture chứa session/CSRF để ngoài Git. Harness unit kiểm tra percentile, inventory và origin. Không có staging URL hay fixture 120 tài khoản dùng một lần, nên tải thật chưa chạy và p95 ≤3.5 giây chưa được chứng minh.

Khi có môi trường phù hợp, tôi sẽ tạo riêng 120 account disposable với cùng độ dài thao tác, xác nhận trước mỗi lần chạy rằng fixture chưa bị dùng và lưu JSON kết quả ra ngoài repository nếu chứa thông tin nhạy cảm. P95 tính nearest-rank trên từng loại request; cần đồng thời zero request failure và cả hai p95 dưới 3500 ms mới kết luận đạt. Một lần chạy trên laptop hoặc database không tương đương production capacity nên kết quả chỉ đại diện cấu hình staging được đo.

Acceptance/risk	Test → file	Commit/PR và evidence
AC1, AC3 transition	T01–04 → tests/backend/unit/test_admin_account_lifecycle.py	4d94be0; RED #43578158304; local pass
AC2, privacy	T05–06 → unit + tests/backend/integration/test_admin_account_endpoints.py	PR #67; unit pass; MySQL run còn thiếu
AC4, consistency; AC5 stale	T07–10 → integration endpoint tests	PR #67; test có, cần MySQL suite mới
NFC1, input safety	T11–12 → tests/load/test_account_lifecycle.py	PR #67; harness test pass; tải chưa đo
Mutation guard	delete valid/repeat tests	a7be787; mutant bị kill ở run lịch sử

7. AI Usage Log và reflection

AI Usage Log. Công cụ: Codex (GPT-6). Prompt chính, tóm lược: đọc yêu cầu VT-068 và nhánh PR; trước khi sửa, nêu plan, assumptions, file và evidence; sau đó giúp rà soát CI và biên tập báo cáo. AI gợi ý cấu trúc acceptance criteria, ma trận transition và các mục cần đối chiếu. Tôi giữ lại phần phù hợp, nhưng tự kiểm tra commit, test file, PR run và chạy lại 12 test local. Khi CI báo route map cũ, tôi chạy generator/check trước khi giữ thay đổi. Khi dependency gate báo CVE, tôi tra changelog upstream rồi cập nhật pin; tôi không coi một câu trả lời của AI là bằng chứng. Code/test lifecycle đã có trên branch trước lượt biên tập này; tôi không ghi nhận như thể AI vừa viết chúng. Hai gợi ý dễ tin nhưng chưa đủ: restore luôn active=true (bỏ qua prior=false) và assert 403 mà không đọc lại side effects (T02/T06 bổ sung góc nhìn).

Reflection. Điều làm tôi yên tâm hơn là test kiểm tra trạng thái sau thao tác, không chỉ xem endpoint trả 200. Test-only commit trên baseline cho thấy contract fail vì thiếu service method; sau đó unit test phân biệt account active và inactive trước xóa. Integration test còn kiểm tra lịch sử liên kết được giữ và session cũ không hồi sinh. Mutation đảo điều kiện deleted-state bị test delete hợp lệ và delete lặp phát hiện. Trong lượt tiếp tục, tôi cài bản telemetry đã vá và chạy lại 12 unit/harness test; tất cả pass trong 1.38 giây. Tôi cũng thấy CI hữu ích ở chỗ tìm ra route-map chưa sinh lại và dependency cũ bị advisory chặn. Tôi chạy generator, kiểm tra output, rồi đọc changelog trước khi đổi pin. Những bằng chứng này làm tôi tự tin hơn vào các phần đã kiểm tra, nhưng không đủ để khẳng định toàn ứng dụng ổn định.

Tôi vẫn chưa có MySQL integration sau head mới, full CI xanh, line/branch coverage, query plan với dữ liệu gần thực tế hay p95 ở 120 người dùng. Không có staging và 120 account/session disposable nên tôi không thể ghi mục tiêu tải là đạt. Bước tiếp theo có giá trị nhất là đợi CI hoàn tất, xem log các job lỗi nếu còn, rồi chạy MySQL 8.4 riêng và harness tại staging cô lập. Nếu lỗi do môi trường hoặc dependency khác, tôi cần phân biệt với regression thay vì bỏ qua. Tôi muốn nhờ thành viên nhóm review thứ tự lock, rollback khi commit outcome không rõ và quyền đọc account đã xóa. PR vẫn Draft, chưa sẵn sàng merge.

Coverage không thể thay test quyền: guard sai vẫn có thể làm lộ dữ liệu. Harness cũng chưa phải số đo nếu thiếu staging và fixture. Khi trình bày với nhóm, tôi sẽ tách kết quả đã test, phần mới có thiết kế và phần còn chờ xác minh.

Ghi chú CI: CI trước khi cập nhật pin đã báo route-map stale và advisory CVE-2026-126360 trên opentelemetry-api 1.45.1. Tôi đã sinh lại route map và cập nhật nhóm OpenTelemetry đồng bộ lên 1.45.2/0.66b2; upstream ghi nhận fix traceparent length ở changelog 1.45.2. Các job trên head mới đang được chạy lại; không đánh dấu chúng pass trước khi có kết quả.